

SHORT WEEKLY EXERCISE 1: LAB WORK

1. 3rdRisk Platform Exploration

As part of the compliance exercise, you are required to watch the videos and explore the features of the 3rdRisk platform as a starting point for becoming familiar with GRC platforms.

<https://support.3rdrisk.com/en/article/control-library>

Once completed, please enter your **full legal name** to confirm completion using the link below:

Please see the link below: <https://forms.gle/2C2RM1DPJaLnnfhZ7>

2. GRC Practice Lab – Control Register, Control Mapping & Control Lifecycle

Step 1: Create an account: <https://johnbjoseph-cybersec.github.io/>

Step 2: Locate Controls and load any of the available demo data. Add 10 additional controls to the existing controls in the Control Register. Map each control to at least two frameworks/standards.

Step 3: Locate Control Lifecycle and add six controls. Each control should represent one of the following lifecycle stages:

Proposed | Designed | Implemented | Operating | Monitoring | Retired

3. Analysis

Take screenshots and analyze the outputs from Steps 2 and 3. Your analysis should explain what you did, the results, and what you learned from the exercise.

See the sample analyses below for guidance, but ensure that your analysis is unique and reflects your own work and even better:

- Faustina Hukportie: https://www.linkedin.com/posts/faustina-hukportie-648a36100_cybersecurity-grc-itaudit-activity-7440000226125537280-l195?utm_source=social_share_send&utm_medium=member_desktop_web&rcm=ACoAABUHptcBmgMKc8Nb_EsjWICdKVWTdDxYQcY
- Prince a. Frimpong: https://www.linkedin.com/posts/prince-a-frimpong-bsc-mba-088850239_yesyoucancybersecure-grc-dr-activity-7439452691732414464-eCOJ?utm_source=social_share_send&utm_medium=member_desktop_web&rcm=ACoAABUHptcBmgMKc8Nb_EsjWICdKVWTdDxYQcY

Submission: Compile all your work into one PDF document and submit it through the Class LMS.

LinkedIn: You may also share your completed work on LinkedIn; however, this is optional.

NAME: CORRIE ADELAIDE BLAY

CYBER ID: 980074118

GRC Practice Lab Analysis

1. Introduction

As part of my compliance exercise, I explored the 3rdRisk platform and completed the GRC Practice Lab. This analysis documents my hands-on experience with the Control Register, Control Mapping, and Control Lifecycle. Through this exercise, I gained practical understanding of how GRC platforms help organizations manage security controls, demonstrate compliance across multiple frameworks, and track control maturity over time.

2. 3rdRisk Platform Exploration

I began by watching the 3rdRisk control library video, which introduced me to how GRC platforms organize and manage security

controls. The platform demonstrated the importance of having a centralized control library that can be mapped to multiple frameworks simultaneously.

Key concepts I learned:

- GRC platforms provide a single source of truth for security controls.
- Controls can be searched, filtered, and categorized for easy management
- The control library is the foundation for compliance and audit readiness

Reflection 1: 3rdRisk Platform Exploration

Exploring the 3rdRisk platform was a good starting point because it showed me how a real control library is structured. I noticed that controls were organized by category and could be filtered by framework, which made it easy to see how one control could relate to multiple standards. It helped me understand that GRC platforms are

not just storage—they are active tools that help teams stay organized

and audit-ready. VIDEO WATCHED AND COMPLETED

The image is a screenshot of a mobile phone screen displaying a Google Forms submission confirmation page. At the top, the status bar shows the time 05:39, LTE signal, and battery level. The main header features the '3rd RISK' logo in large, bold, dark green letters, with the tagline 'Connecting for a brighter tomorrow' underneath. The central content area is a white box with a rounded border, containing the title 'Mandatory Training as part of compliance' in bold black text. Below the title, it says 'Your response has been recorded.' and provides a blue link 'Submit another response'. At the bottom of the white box, there is a disclaimer: 'This content is neither created nor endorsed by Google. - [Contact form owner](#) - [Terms of Service](#) - [Privacy Policy](#).' Below the white box, there is a question 'Does this form look suspicious?' followed by a blue link 'Report'. The Google Forms logo is centered below this. The bottom of the screen shows a dark navigation bar with a hamburger menu icon, the URL 'docs.google.com', a refresh icon, and four other icons: a back arrow, a forward arrow, a share icon, and a tab icon. A white horizontal line is visible at the very bottom of the screen.

05:39 LTE

3rd RISK

Connecting for a brighter tomorrow

Mandatory Training as part of compliance

Your response has been recorded.

[Submit another response](#)

This content is neither created nor endorsed by Google. - [Contact form owner](#) - [Terms of Service](#) - [Privacy Policy](#).

Does this form look suspicious? [Report](#)

Google Forms

docs.google.com

3. Control Register - What I Did

For the GRC Practice Lab, I loaded the CloudPay (Fintech) scenario, which provided 25 pre-built controls covering frameworks including NIST CSF, ISO 27001, PCI DSS, SOC 2, and CIS.

I then added 10 additional controls to the Control Register. These controls covered multiple security domains:

#	Control Name	Category	Primary Framework	Second Framework
1	Access Control Policy	Access Control	NIST CSF (PR.AC-1)	ISO 27001 (A.9.1.1)
2	Multi-Factor Authentication	Access Control	NIST CSF (PR.AC-7)	PCI DSS (8.3)
3	Password Management Policy	Access Control	NIST CSF (PR.AC-1)	PCI DSS (8.2.3)
4	Security Awareness Training	Awareness & Training	NIST CSF (PR.AT-1)	ISO 27001 (A.7.2.2)
5	Incident Response Plan	Incident Management	NIST CSF (RS.RP-1)	ISO 27001 (A.16.1.5)
6	Data Encryption	Cryptography	NIST CSF (PR.DS-1)	PCI DSS (3.4)
7	Vendor Risk Assessment	Vendor Management	NIST CSF (ID.SC-2)	ISO 27001 (A.15.1.1)

8	Employee Background Checks	Operations Security	NIST CSF (PR.IP-11)	SOC 2 (CC1.2)
9	Physical Access Controls	Physical Security	NIST CSF (PR.AC-3)	ISO 27001 (A.11.1.1)
10	Audit Logging and Monitoring	Logging & Monitoring	NIST CSF (DE.AE-2)	SOC 2 (CC7.2)

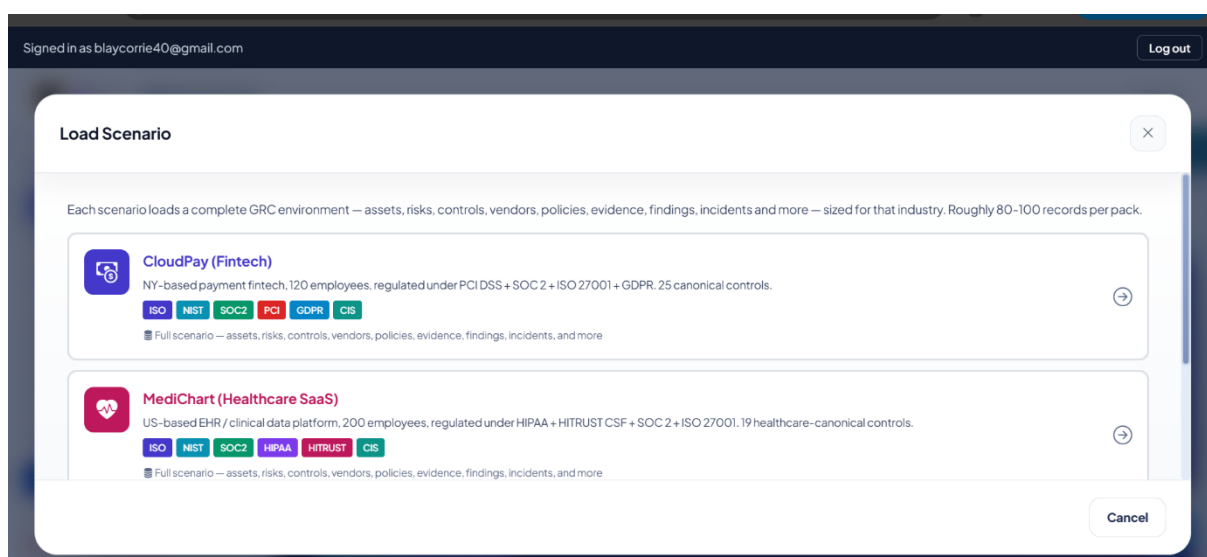
CloudPay (Fintech) scenario

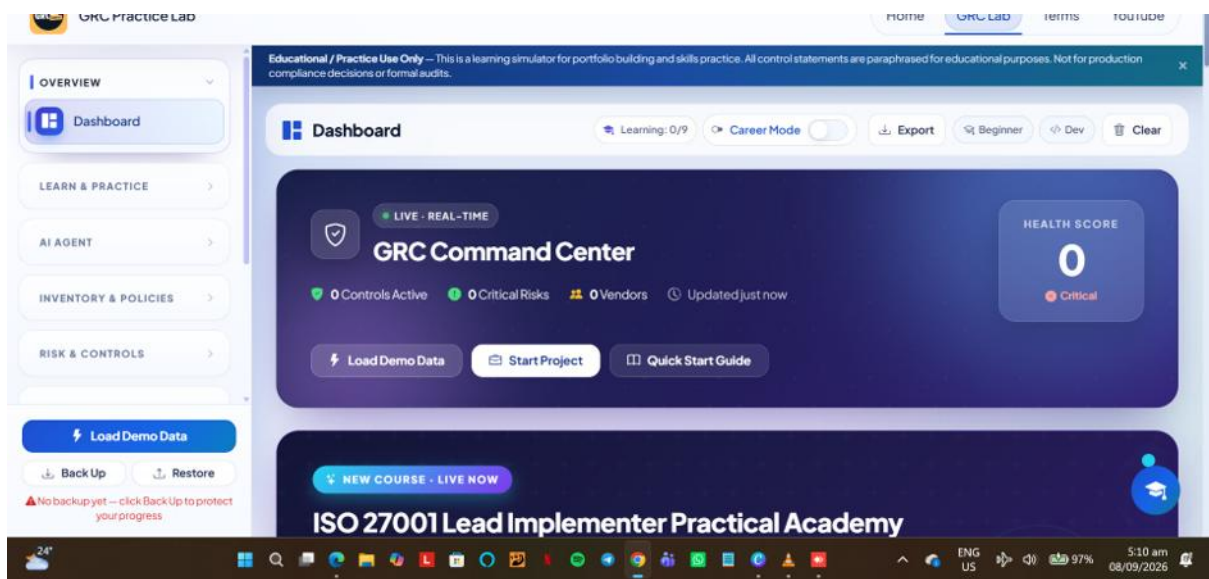
After adding all controls, my Control Register showed:

- **35** Total Controls (25 demo + 10 added)
- **29** Effective (83%)
- **6** Partial
- **0** Ineffective

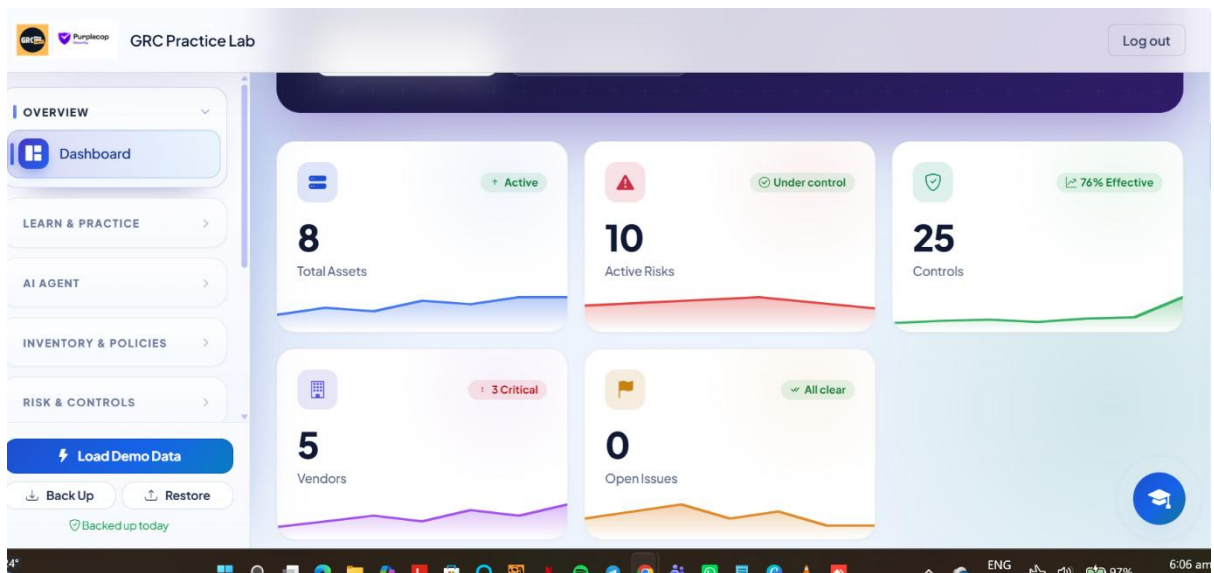
- **MY REFLECTION:**

One thing that stood out to me was the platform's COACHTIP about writing specific and testable controls. At first, I thought a control like "implement security" was fine, but I learned it is too vague. A better control is something like "enforce MFA on all admin accounts using Okta with hardware keys"—it tells you exactly what is being done, how, and how you would test it. That distinction made me realize that good controls are written for auditors, not just for internal teams. I also learned that categorizing controls correctly (Access Control, Cryptography, Incident Management, etc.) makes the register much easier to navigate and helps identify gaps in coverage.

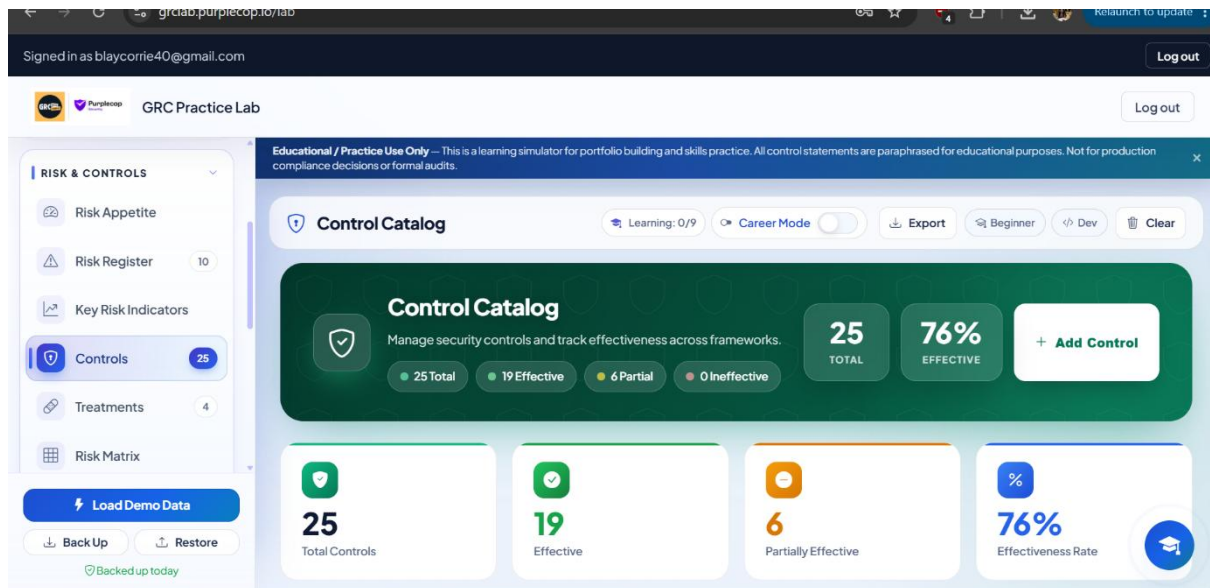




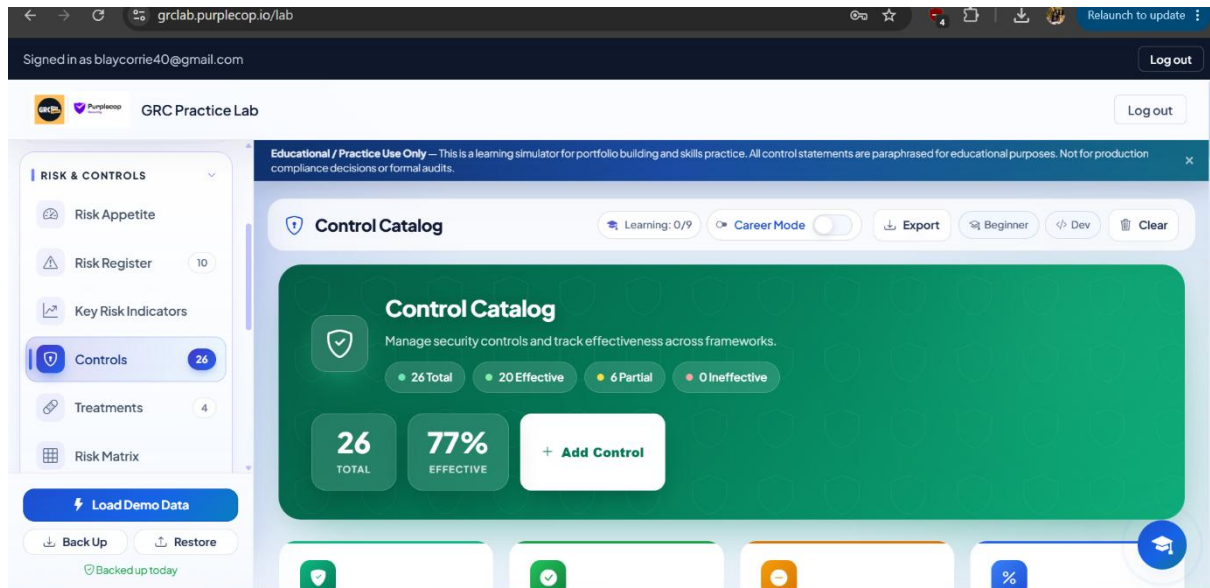
BEFORE ALL CONTROLLS WERE ADDED



DEFAULT 25 CONTROLS ON THE GRC LAB



AFTER FIRST CONTROL WAS ADDED



AFTER ADDITIONAL 10 CONTROLS WAS ADDED

Signed in as blaycorrie40@gmail.com Log out

GRC Practice Lab

Log out

Key Risk Indicators

Controls 35

Treatments 4

Risk Matrix

Control Mapping

Control Lifecycle

Cloud Risk Assessment

Load Demo Data

Back Up Restore

Backed up today

Educational / Practice Use Only — This is a learning simulator for portfolio building and skills practice. All control statements are paraphrased for educational purposes. Not for production compliance decisions or formal audits.

Control Mapping

Learning: 0/9 Career Mode Export Beginner Dev Clear

UNIFIED CCF - ENTERPRISE

35 CONTROLS

173 MAPPINGS

6/6 FRAMEWORKS

+ Add

Define a control **once** — map it across multiple frameworks and satisfy every regulator.

Framework Coverage

% of applicable requirements with at least one mapped control - N/A items excluded - click to filter

ISO 27001 64%
52/81 applicable - 21 N/A 58 maps

NIST CSF 2.0 29%
31/106 applicable 40 maps

SOC 2 (TSC) 40%
17/43 applicable - 18 N/A 19 maps

PCI DSS 4.0 40%
24/60 applicable - 3 N/A 27 maps

25°

ENG US 100% 7:11 am 10/09/2026

Signed in as blaycorrie40@gmail.com Log out

GRC Practice Lab

Log out

Key Risk Indicators

Controls 35

Treatments 4

Risk Matrix

Control Mapping

Control Lifecycle

Cloud Risk Assessment

Load Demo Data

Back Up Restore

Backed up today

Educational / Practice Use Only — This is a learning simulator for portfolio building and skills practice. All control statements are paraphrased for educational purposes. Not for production compliance decisions or formal audits.

Control Catalog

Learning: 0/9 Career Mode Export Beginner Dev Clear

Control Catalog

Manage security controls and track effectiveness across frameworks.

35 Total

29 Effective

6 Partial

0 Ineffective

35 TOTAL

83% EFFECTIVE

+ Add Control

25°

ENG US 100% 7:12 am 10/09/2026

4. Control Mapping - What I Did

I mapped each of my 10 controls to at least two frameworks. My approach was:

- **Primary Framework:** NIST CSF (universal, framework-agnostic)
- **Second Framework:** ISO 27001, PCI DSS, or SOC 2 depending on the control's purpose

Why I chose these mappings:

- NIST CSF provided the foundational structure (Identify, Protect, Detect, Respond, Recover)
- ISO 27001 covered international best practices
- PCI DSS addressed payment security requirements (critical for CloudPay)
- SOC 2 demonstrated trust service criteria

The Control Mapping section showed:

- **173 Total Mappings** across all controls

- **ISO 27001 Coverage:** 64%
- **NIST CSF Coverage:** 29%
- **SOC 2 Coverage:** 40%
- **PCI DSS Coverage:** 40%

What I learned:

- **Unified Control Mapping:** One control can satisfy multiple frameworks, reducing duplication and audit burden
- **Framework Relationships:** NIST CSF references map to specific ISO 27001 controls (e.g., [PR.AC-1](#) → A.9.1.1)
- **Efficiency:** Without unified mapping, the same control would need to be documented and tested separately for each framework.

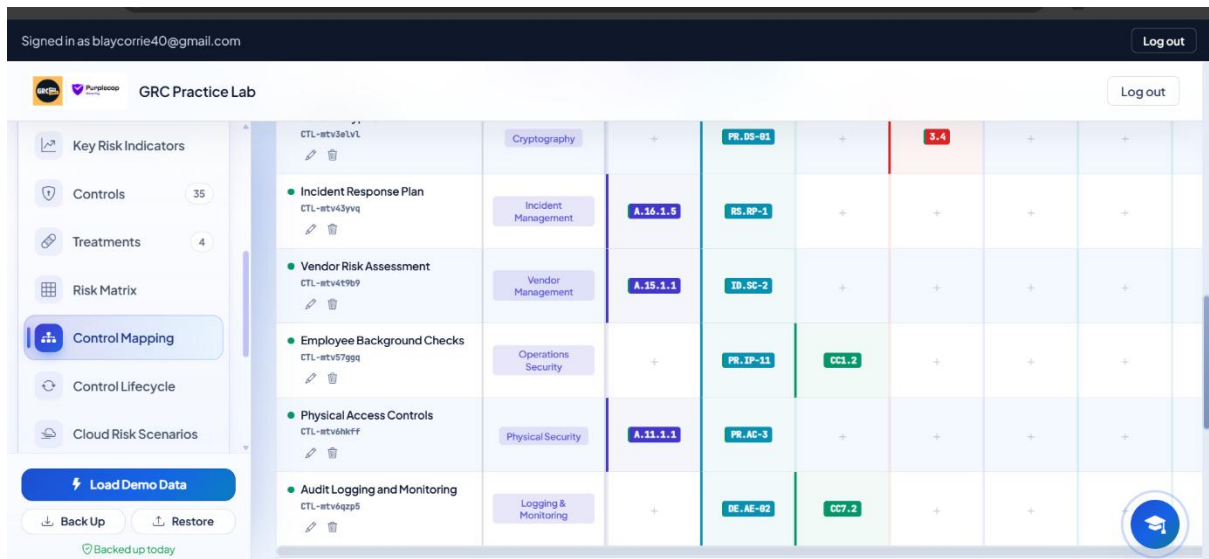
MY REFLECTION:

The most valuable lesson for me was seeing how one control can satisfy multiple frameworks at the same time. For example, my Multi-Factor

Authentication control mapped to NIST [PR.AC-7](#), PCI DSS 8.3, and SOC 2 CC6.1. Before this exercise, I assumed each framework needed its own separate control documentation. Now I understand that unified control mapping reduces duplication, saves time during audits, and ensures consistency across compliance efforts. I also learned that framework references like [PR.AC-1](#) or A.9.1.1 are not just numbers—they represent specific requirements that auditors will look for.

The screenshot displays the GRC Practice Lab interface. On the left is a sidebar with navigation options: Controls (27), Treatments (4), Risk Matrix, Control Mapping (selected), Control Lifecycle, and Cloud Risk Scenarios. Below this is an 'AUDIT & COMPLIANCE' section with buttons for 'Load Demo Data', 'Back Up', and 'Restore', along with a 'Backed up today' status. The main area features a 'Control x Framework Matrix' table. Above the table are summary cards for 'GDPR' (27% complete, 9/33 applicable, 4 N/A, 10 maps) and 'CIS Controls v8' (11% complete, 19/171 applicable, 19 maps). Below these are tabs for 'Matrix', 'List', and 'Gap Analysis', a search bar, and dropdowns for 'All Frameworks' and 'All Categories'. The matrix table has columns for 'INTERNAL CONTROL', 'CATEGORY', 'ISO', 'NIST', 'SOC2', 'PCI', 'GDPR', and 'CIS'. Two controls are visible: 'Multi-Factor Authentication for All Privileged & Customer-Facing Access' (UC-001) and 'Centralized SIEM with 24/7 Monitoring & Alerting' (UC-002). The first control is mapped to ISO A.8.5, NIST PR.AC-03, SOC2 CC6.1, PCI 8.4, and CIS 6.5. The second control is mapped to ISO A.8.16 and A.8.15, NIST DE.CM-01, SOC2 CC7.2, PCI 10.2 and 10.4, and CIS 5.4. A 'Logout' button is in the top right corner.

INTERNAL CONTROL	CATEGORY	ISO	NIST	SOC2	PCI	GDPR	CIS
Multi-Factor Authentication for All Privileged & Customer-Facing Access UC-001	Access Control	A.8.5	PR.AC-03	CC6.1	8.4	+	CIS 6.5
Centralized SIEM with 24/7 Monitoring & Alerting UC-002	Logging & Monitoring	A.8.16 A.8.15	DE.CM-01	CC7.2	10.2 10.4	+	CIS 5.4



5. Control Lifecycle - What I Did

I added six controls to the Control Lifecycle, each representing one stage:

Stage	Control Name	Owner	Maturity
Proposed	Cloud Access Control Policy	IAM Team	1/5
Designed	Zero Trust Architecture	Security Architecture	2/5
Implemented	Endpoint Protection Suite	IT Operations	3/5

Operating	Network Firewall Rules	Network Security	4/5
Monitoring	SOC 2 Compliance Monitoring	Compliance Team	5/5
Retired	Legacy VPN Solution	Network Security	1/5

The lifecycle Pipeline showed one control in each stage, demonstrating the full journey from proposal to retirement.

What I learned;

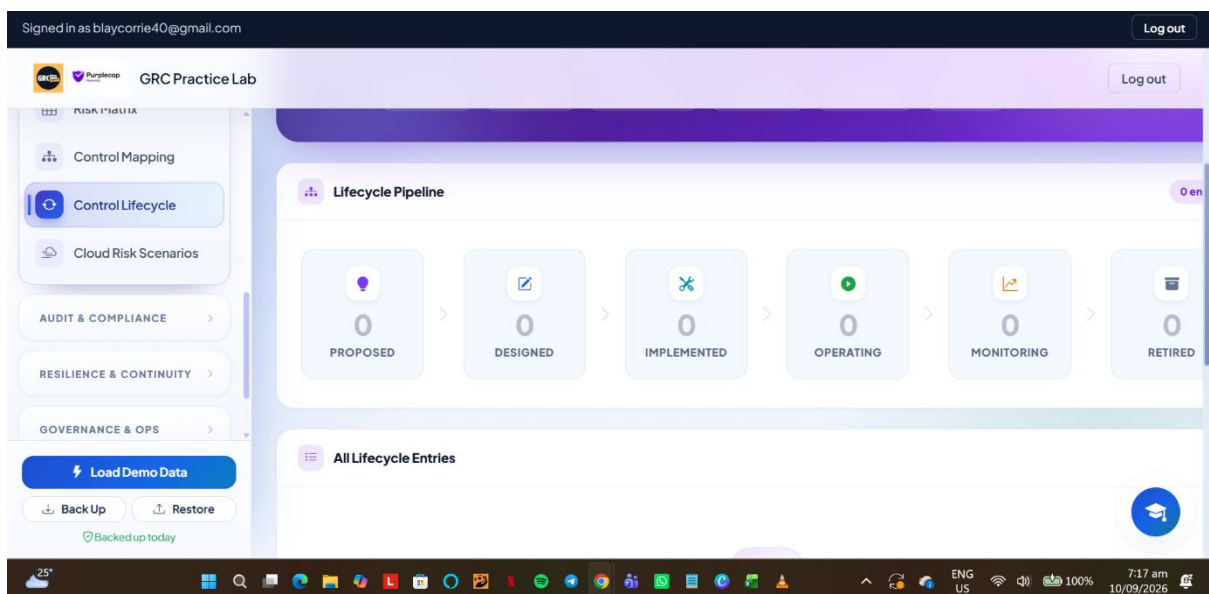
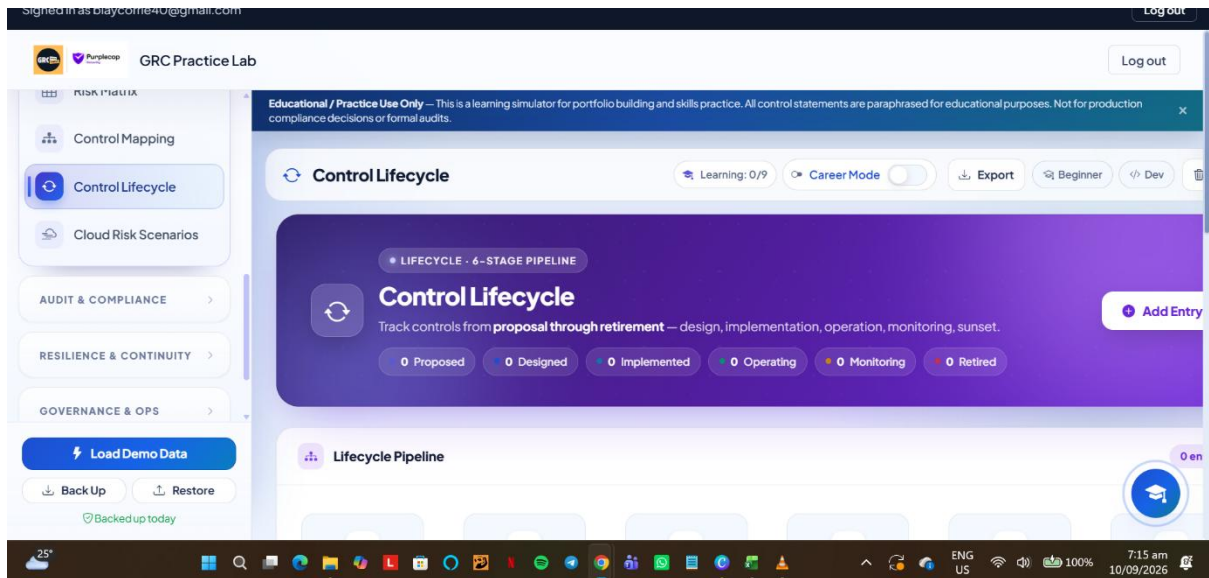
- Controls are not static—they evolve from proposal through design, implementation, operation, monitoring, and eventual retirement
- Maturity levels (1-5) indicate how developed each control is

- The lifecycle view helps auditors understand control maturity and identify gaps
- Tracking the lifecycle ensures controls are regularly reviewed and updated

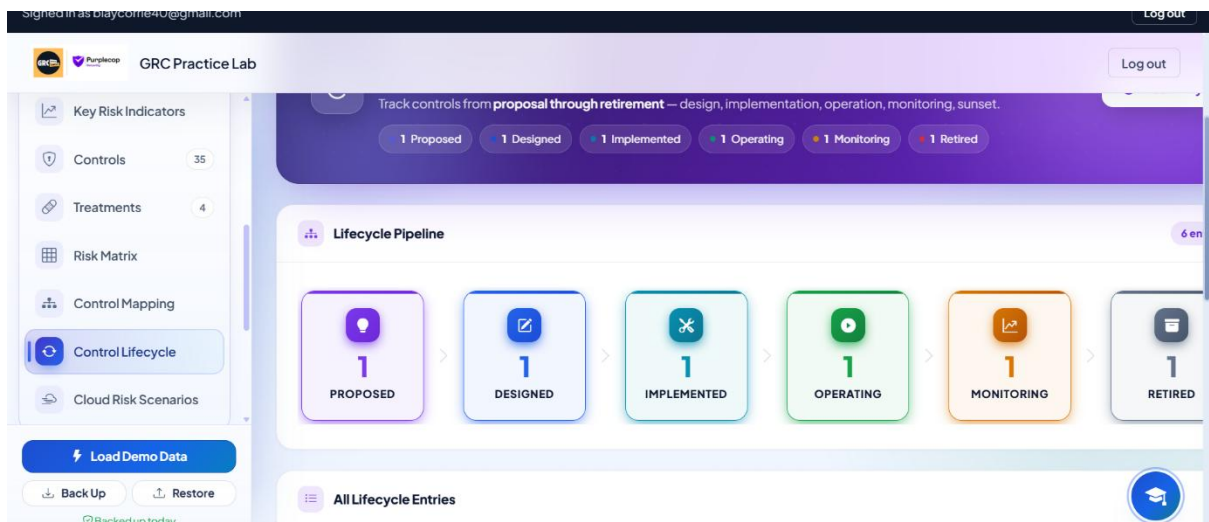
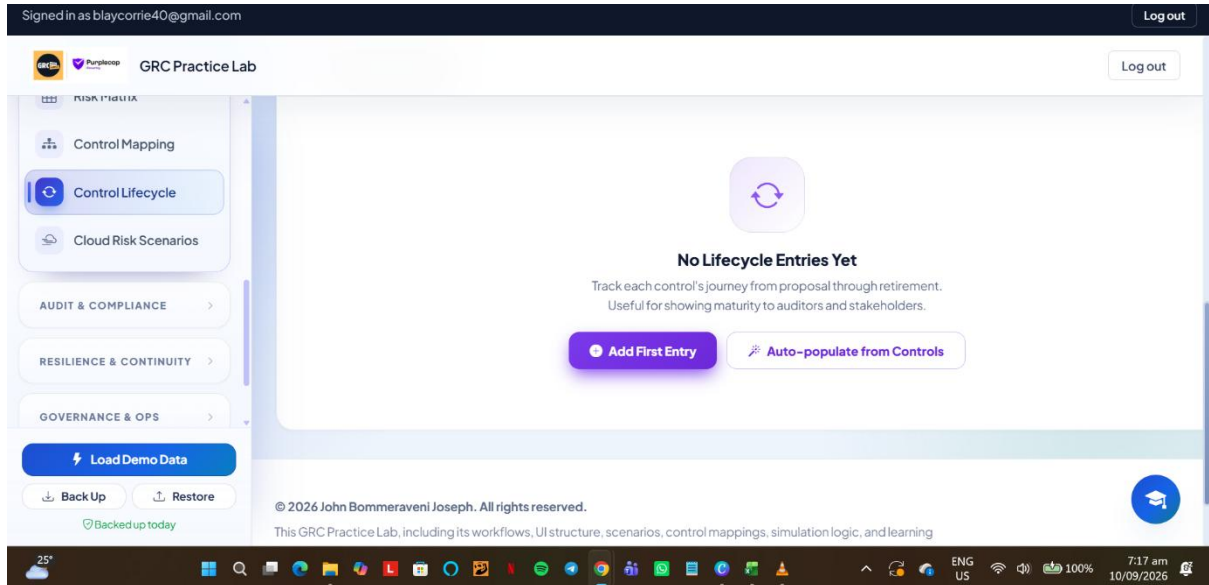
My reflection:

I found the lifecycle concept useful because it showed me that controls are not static. They start as proposed ideas, get designed, implemented, operated, monitored, and eventually retired when they are no longer needed or have been replaced. The maturity levels (1–5) also helped me understand that a control can be effective but still have room to grow. For example, my SOC 2 Compliance Monitoring control had a maturity of 5/5 because it was fully optimized, while my Cloud Access Control Policy was only 1/5 because it was still in the proposal stage. This made me realize that GRC is not just about having controls—it is about continuously improving them.

CONTROL LIFECYCLE BEFORE I CREATED THEM



BEFORE LIFECYCLES WERE ENTERED



Signed in as blaycorrie40@gmail.com Log out

GRC Practice Lab Log out

- Key Risk Indicators
- Controls 35
- Treatments 4
- Risk Matrix
- Control Mapping
- Control Lifecycle**
- Cloud Risk Scenarios

Load Demo Data

Back Up Restore

Backed up today

CONTROL NAME	PHASE	OWNER	DESIGN	GO-LIVE	NEXT REVIEW	MATURITY	AC
Cloud Access Control Policy	PROPOSED	IAM Team	2026-09-01	2026-09-02	2026-09-03	1/5	
Zero Trust Architecture	DESIGNED	Security Architecture	2026-09-04	2026-09-05	2026-09-06	3/5	
Endpoint Protection Suite	IMPLEMENTED	IT Operations	2026-09-04	2026-09-06	2026-09-08	4/5	
Network Firewall Rules	OPERATING	Network Security	2026-09-07	2026-09-10	2027-02-01	5/5	
SOC 2 Compliance Monitoring	MONITORING	Compliance Team	2026-09-09	2026-09-10	2027-09-03	5/5	
Legacy VPN Solution	RETIRED	Network Security	2026-09-11	2026-09-20	2026-10-01	1/5	

6. Analysis - What I Learned

Key Takeaway 1: Unified Control Mapping is Essential

Modern organizations face multiple overlapping frameworks. A fintech like CloudPay must comply with PCI DSS, SOC 2, ISO 27001, and GDPR simultaneously. Without unified control mapping, the same MFA implementation would be documented and tested separately for each framework, leading to duplication and inefficiency.

Key Takeaway 2: Framework References Matter

Understanding the specific references ([PR.AC-1](#), A.9.1.1, 8.3, CC6.1) allows GRC professionals to communicate effectively with auditors and demonstrate compliance. Each reference represents a specific requirement that the control satisfies.

Key Takeaway 3: Control Lifecycle Demonstrates Maturity

Tracking controls through their lifecycle shows auditors that the organization is not just implementing controls but also monitoring, reviewing, and retiring them appropriately. This demonstrates a mature GRC program.

Key Takeaway 4: Categorization is Important

Grouping controls by category (Access Control, Cryptography, Incident Management, etc.) makes the Control Register easier to navigate and understand. It also helps identify gaps in coverage.

Key Takeaway 5: Hands-On Experience is Invaluable

Working directly with a GRC platform helped me understand concepts that are difficult to grasp from reading alone—such as the relationship between controls and frameworks, the importance of evidence, and the value of lifecycle tracking.

7. Conclusion

This exercise provided practical, hands-on experience with a GRC platform and demonstrated the core components of a GRC program:

- **Control Register:** Centralized repository of security controls

- **Control Mapping:** Linking controls to multiple frameworks
- **Control Lifecycle:** Tracking controls from proposal to retirement

These skills are directly applicable to GRC analyst roles, compliance management, audit preparation, and risk management.

My Final Reflection:(CONCLUSION)

As someone new to GRC, this exercise gave me confidence that I can navigate a GRC platform and understand the core concepts. I started the assignment feeling confused about frameworks and controls, but by the end I could clearly explain how controls are added, mapped, and tracked through their lifecycle. I am excited to apply these skills in a real-world GRC role, and I now understand why organizations invest in GRC platforms—they make compliance manageable, repeatable, and audit-ready.